

Kit de Gestión del Programa GRC y Modelo Operativo

Repository release 1.11 | 1 August 2026

Versión del repositorio: 1.11

Fecha de publicación: 1 de agosto de 2026

Autor: Alberto "Al" Leiva

Propósito

Este kit práctico ayuda a establecer y operar un programa trazable de gobierno, riesgo y cumplimiento (GRC). Integra mandato, gobernanza, planificación, priorización, cartera, capacidad, decisiones, escalamiento, excepciones, madurez, revisión ejecutiva y mejora continua.

Limitación importante

Este material ofrece orientación educativa y operativa. No constituye asesoría legal, interpretación regulatoria, certificación, aseguramiento de auditoría ni prueba de eficacia. Cada organización debe adaptarlo a sus obligaciones, riesgos, autoridad y modelo operativo.

Cómo usar el kit

Use los capítulos para diseñar o mejorar el programa y las seis herramientas CSV como puntos de partida controlados. Asigne una persona responsable, vincule evidencia, conserve aprobaciones y defina fechas de revisión. Una plantilla, puntuación, reunión o tablero completado no demuestra por sí solo que la gobernanza o los controles sean eficaces.

Herramientas editables

- `GRC_Program_Charter.csv`: 22 campos controlados.
- `GRC_Operating_Model_and_RACI.csv`: 18 campos controlados.
- `Annual_GRC_Plan_and_Calendar.csv`: 19 campos controlados.
- `GRC_Initiative_Portfolio_Tracker.csv`: 24 campos controlados.
- `Governance_Meeting_and_Decision_Log.csv`: 20 campos controlados.
- `GRC_Maturity_Assessment.csv`: 20 campos controlados.

Estatuto, Mandato y Principios Operativos

Propósito y resultados

Defina por qué existe el programa GRC, qué decisiones apoya, qué resultados espera y cuáles son los límites de su autoridad. Conecte obligaciones, riesgo empresarial, seguridad, privacidad, resiliencia, aseguramiento y objetivos del negocio sin atribuir al programa la propiedad de todos los controles.

Elementos mínimos del estatuto

Registre patrocinador, mandato, alcance, exclusiones, derechos de decisión, autoridad de escalamiento, informes, ciclo de revisión, supuestos de recursos y evidencia de aprobación. Distinga autoridad consultiva de autoridad aprobadora.

Principios operativos

Aplique trazabilidad, proporcionalidad, independencia cuando corresponda, juicio documentado, rendición de cuentas, limitaciones visibles y mejora continua. Un marco o tablero apoya la gobernanza; no prueba cumplimiento.

Implementación práctica

Entreviste a patrocinadores y propietarios de controles; mapee foros y obligaciones; identifique decisiones duplicadas o ausentes; prepare el estatuto; obtenga aprobación formal; publique con control de versiones; revíselo al menos anualmente o ante cambios materiales.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Evidencia de implementación

Conserve el estatuto aprobado, delegaciones, términos de referencia, RACI vigente, registros de decisiones y excepciones, líneas base, supuestos de capacidad y revisiones de eficacia. Registre opciones rechazadas y disenso cuando sean materiales.

Foros de Gobernanza, Derechos de Decisión y RACI

Arquitectura de gobernanza

Diseñe pocos foros con propósitos distintos: supervisión ejecutiva, coordinación operativa, aceptación de riesgo, aprobación de políticas, revisión de excepciones y seguimiento de aseguramiento. Evite comités que reciben información pero no pueden decidir.

Diseño de derechos de decisión

Para cada decisión identifique quién recomienda, cuestiona, aprueba, ejecuta, registra y recibe notificación. Defina cuórum, autoridad delegada, plazos, conflictos de interés y rutas de escalamiento.

Controles RACI

Use RACI para comunicar, no para sustituir la responsabilidad. Cada actividad debe tener una sola función accountable, funciones responsables realistas y un grupo consultado limitado.

Eficacia de los foros

Mida asistencia, decisiones completadas, acciones vencidas, escalamientos repetidos, latencia y conflictos sin resolver. Retire foros o temas que ya no aporten valor.

Fallas frecuentes

Incluyen varias funciones accountable, foros sin autoridad, delegaciones no registradas, aceptación de riesgo no autorizada y matrices RACI distintas de la práctica. Corrija el modelo cuando la conducta y la documentación diverjan.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Planificación Anual, Admisión y Priorización

Ciclo de planificación

Convierta estrategia, evaluaciones de riesgo, obligaciones, hallazgos, incidentes, cambios tecnológicos y planes de negocio en una cartera gobernada. Mantenga un horizonte móvil y no un plan anual estático.

Admisión controlada

Registre solicitante, problema, obligación o riesgo, alcance, urgencia, dependencias, esfuerzo estimado, decisión requerida y vínculos de evidencia.

Modelo de priorización

Puntúe urgencia, exposición, plazo legal, impacto al cliente, dependencia de controles, esfuerzo y valor estratégico. Conserve la justificación y permita anulaciones documentadas por la autoridad correspondiente.

Compromiso según capacidad

No apruebe más trabajo del que el programa pueda gobernar. Identifique capacidades escasas, dependencias, presupuesto, compras, datos y cuellos de decisión antes de comprometer fechas.

Evidencia de admisión y prioridad

Conserve solicitud, criterios, fuentes, conflictos, dependencias, estimación, decisión, anulación autorizada y próxima revisión. Vuelva a puntuar después de cambios materiales.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Cartera, Capacidad y Control de Entrega

Estructura de cartera

Mantenga una cartera de iniciativas, obligaciones recurrentes, remediación y mejora. Separe compromisos obligatorios de mejoras discrecionales y muestre dependencias compartidas.

Hitos y evidencia

Defina hitos por resultados, criterios de aceptación, responsables, fechas, dependencias, ubicaciones de evidencia y puertas de decisión. Un porcentaje sin evidencia no basta.

Gestión de capacidad

Mida capacidad por función y habilidad crítica, no solo por número de personas. Reserve capacidad para incidentes, cambios regulatorios urgentes, auditorías y decisiones ejecutivas.

Intervención de entrega

Defina umbrales para retrasos, bloqueos, crecimiento de alcance, variaciones de recursos y evidencia faltante. El escalamiento debe provocar una decisión.

Cadencia de revisión

Compare capacidad planificada y real, hitos, evidencia, decisiones y resultados. Cierre una iniciativa solo después de registrar aceptación y evidencia; archive sin borrar el historial.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Reuniones, Decisiones, Escalamientos y Excepciones

Reuniones centradas en decisiones

Cada reunión recurrente debe tener mandato, responsable, participantes, entradas, tipos de decisión, agenda, fecha de prelectura y regla de retención.

Registros de decisión

Capture decisión, fecha, autoridad, opciones, fundamento, condiciones, cuestionamientos, evidencia, responsable de acción, vencimiento y disparador de revisión.

Disciplina de escalamiento

Escale cuando autoridad, tolerancia al riesgo, recursos, plazos o conflictos excedan el mandato del equipo. Indique la decisión exacta requerida.

Gobernanza de excepciones

Toda excepción requiere alcance, justificación, análisis de riesgo, medidas compensatorias, propietario, autoridad, vencimiento, monitoreo y evidencia de cierre. Una excepción permanente debe convertirse en una decisión explícita de política o diseño.

Salvaguardas

Limite toda excepción en el tiempo. Defina indicadores, riesgo residual y autoridad de prórroga o cierre. El vencimiento no equivale a aprobación. Excepciones repetidas deben activar revisión de política, diseño, recursos o tratamiento.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Madurez, Revisión Ejecutiva y Mejora Continua

Evaluación de madurez

Evalúe mandato, gobernanza, planificación, integración de riesgos, calidad de datos, disciplina de entrega, coordinación de aseguramiento y mejora. Puntúe con criterios definidos y evidencia conservada.

Revisión operativa ejecutiva

Presente decisiones necesarias, cambios materiales, compromisos en riesgo, restricciones, acciones vencidas, excepciones, temas de aseguramiento y prioridades. Evite métricas decorativas.

Lista de mejoras

Convierta lecciones de auditorías, incidentes, retrasos, comentarios y retrospectivas en mejoras priorizadas con responsables y criterios medibles.

Límites de aseguramiento

La autoevaluación y la revisión gerencial no reemplazan el aseguramiento independiente. Distinga validación gerencial, cumplimiento, auditoría interna, auditoría externa, asesoría legal y certificación.

Salvaguardas de puntuación

Defina niveles antes de puntuar, cite evidencia, registre brechas e incertidumbre y separe aspiración de estado actual. Una autoevaluación puede orientar mejoras, pero no debe describirse como validación independiente.

Preguntas de control

- ¿La función responsable está explícita?
- ¿La decisión o el resultado está definido?
- ¿Se registran evidencia, limitaciones y fechas de revisión?
- ¿El escalamiento responde a un umbral claro?
- ¿Se distingue el aseguramiento independiente de la revisión gerencial?

Fuentes, Límites de Uso y Revisión Humana

Base de fuentes

El kit se informa por los resultados de gobernanza de NIST Cybersecurity Framework 2.0, la serie NIST IR 8286, ISO 31000:2018 y las Normas Globales de Auditoría Interna de 2024, vigentes desde el 9 de enero de 2025. El registro del repositorio documenta editor, estado, uso, acceso y sustitución.

Limitaciones de revisión humana

Las pruebas automatizadas validan estructura, encabezados, esquemas CSV, integridad DOCX, texto buscable en PDF, sumas de comprobación y características visuales seleccionadas. No realizan revisión legal o regulatoria específica, aprobación editorial nativa, pruebas con tecnologías de asistencia, aseguramiento independiente, certificación, validación de datos organizacionales ni aprobación de derechos de decisión.

Esta edición es un candidato de publicación con traducción asistida por máquina. Una persona calificada de español latinoamericano debe revisar terminología, significado, tono y adecuación jurisdiccional antes de su aprobación organizacional.